

UNIT - III

DIGITAL SIGNATURE AND APPLICATIONS AND SECURITY AT TRANSPORT LAYER

Digital Signature :-

change kmh
CT

Q1. Write processing steps / algorithm of DSA (Digital Signature Algorithm)

Ans. # Digital Signature - is a verification method. Digital signatures do not provide confidential communication.

- If you want to achieve confidentiality, both the message and the signature must be encrypted using either a secret key or a public key cryptosystem.
- This additional layer of security can be incorporated into a basic digital signature scheme.

→ Methods of Digital Signature

- ① These two are standard approaches to implement the Digital Signature.
- ① Rivest - Shamir - Adleman (RSA)
- ② Digital Signature Algorithm (DSA)

→ Digital Signature Algorithm (DSA)

• The DSA is a cryptographic algorithm used to generate and verify digital signatures, providing a secure way to authenticate the origin and integrity of digital msgs or documents.

• Key Concepts

→ Digital Signature - a unique string of data that is created using a private key and is attached to a msg to prove its authenticity.

→ Public and Private Keys - DSA uses asymmetric cryptography, where a private key is used to create the signature, and a corresponding public key is used to verify it.

→ Hashing - The original msg is first hashed using a cryptographic hash function, such as SHA-256, to produce a fixed-size output.

→ Steps of RSA:-

1. Key Generation

- Choose prime no.s p and q and a generator g .
- Select a private key x such that $0 < x < q$.
- Compute the public key y as $y = g^x \text{ mod } p$.
- The public key (p, q, g, y) is shared, while x is kept secret.

2. Signing Process

→ To sign a msg M , the sender (using their private key) follows these steps:

- Hash the msg M : use a secure hash function (like SHA-256) to compute a hash $H(M)$ of the msg.
 - Generate a random no. k - Choose a unique random integer k for each msg, where $0 < k < q$.
 - Calculate the signature components:

$$r = (g^k \text{ mod } p) \text{ mod } q$$

$$s = (k^{-1} \times (H(M) + x \times r) \text{ mod } q)$$
 where k^{-1} is the modular inverse of k modulo q .
- The signature is the pair (r, s) .

3. Verification Process

To verify a signature (r, s) on a msg M , the receiver (using the sender's public key) performs these steps :-

- check validity of 'r' and 's' :

Ensure $0 < r < q$ and $0 < s < q$; if not, the signature is invalid.

- Hash the msg : Compute $H(M)$ for received msg M

- Calculate intermediate values

- Compute $w = s^{-1} \bmod q$
- Compute $w_1 = (H(M) \times w) \bmod q$
- Compute $w_2 = (r \times w) \bmod q$

- Compute the value of v :

$$v = (g^{w_1} \times y^{w_2} \bmod p) \bmod q$$

- check result - if $v = r$, the signature is valid.

Web Security Considerations :-

→ A Comparison of Threats on the web :-

	Threats	Consequences	Countermeasures
Integrity	• Modification of user data • Poisoned search engines • Modification of memory • Modification of msg traffic in transit	• loss of information • Compromise of m/c • Vulnerability to all other threats	Cryptographic checksums
Confidentiality	• Eavesdropping on the net • Theft of info from servers • Theft of data from client browsers • Info about network configurations • Info about which client talks to servers	• loss of information • loss of privacy	Encrypts, web proxies

Denial of Service	• Killing of user threats • Flooding m/c with bogus requests • Filling up disk or memory • Isolating m/c by DNS attacks	• Disruptive • Annoying • Prevent users from getting work done	Difficult to prevent
Authentication	• Impersonation of legitimate users • Data forgery	• Misrepresentation of users • Belief that fake info is valid	Cryptographic techniques

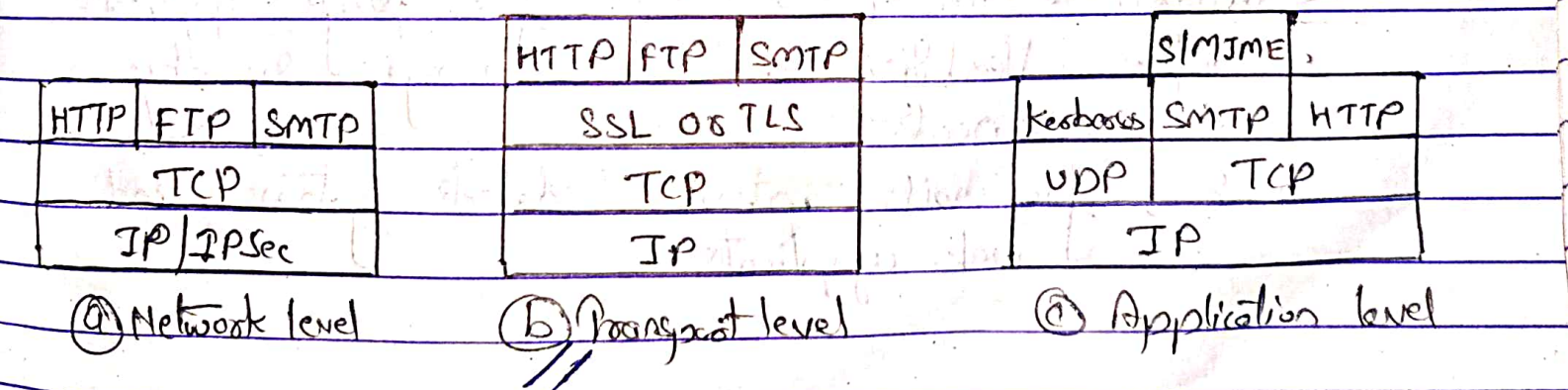


Fig: Relative location of security facilities in the TCP/IP Protocol Stack

→ Web Security approaches :-

① IPsec (IP Security) :-

- Provides a general-purpose security solutn at the IP layer
- Offers transparency to end-users and applications
- Includes filtering capabilities to minimize overhead.

② SSL/TLS (Secure Sockets Layer/Transport Layer Security)

- Provides security at the transport layer / TCP
- Can be implemented transparently as embedded in specific applications
- Offers encryption, authentication, and integrity protection.

③ Application - Specific Security :

- Tailored security solutions for specific applications
- Offers flexibility to address unique security needs
- Ex: firewalls, intrusion detection systems, and web applications

Combining Encrypts and signatures - SignCrypts, SSL-Architecture, Protocols, SSL msg formats, Transport layer security, Kerberos Password management.

- Q1^{Pro} Explain SignCrypts briefly
- Q2^{Pro} Explain the SSL/TLS architecture in detail
- Q3^{Pro} Explain Kerberos with key components

SignCrypts

- SignCrypts is a cryptographic primitive that combines the functionalities of digital signatures and public-key encrypts into a single operation.
- It offers both confidentiality and authenticity in a more efficient manner than performing these operations separately.

⇒ How SignCrypts works :-

① Key Generation :-

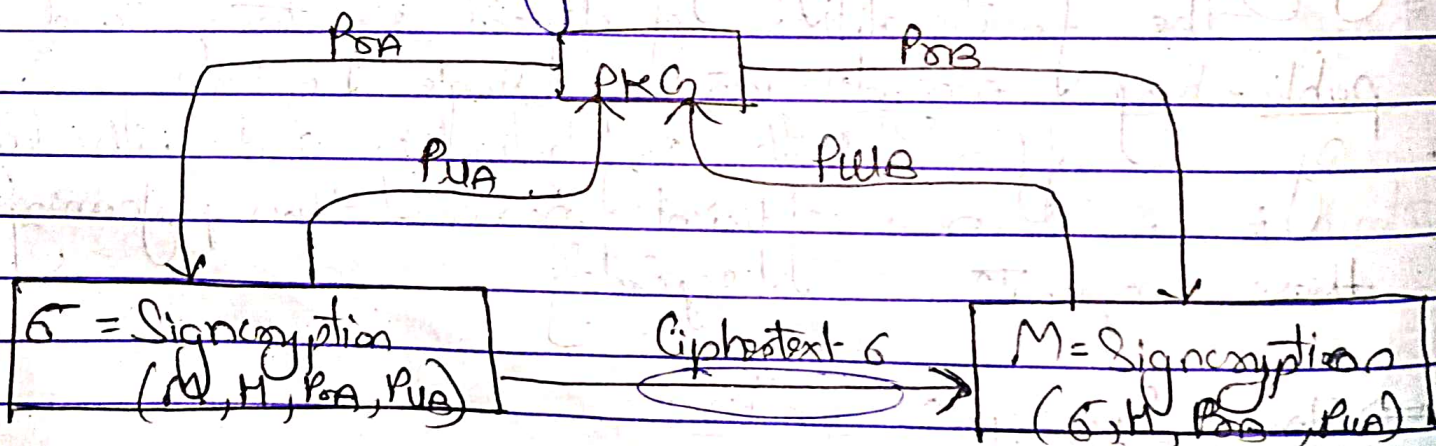
- Each user generates a pair of public and private keys.

② Signcryption

- The sender encrypts the msg using a symmetric key derived from the recipient's public key.
- The sender then signs the ciphertext using their private key.
- The encrypted msg and the signature are combined into a single ciphertext.

③ Unsigncrypt:

- The recipient uses their private key to decrypt the ciphertext and verify the signature.



logical representation of signcrypt process

Kerberos Password Management

Kerberos : A Secure Authentication Protocol

- Kerberos is a network authentication protocol that provides secure authentication for client-server applications by using secret-key cryptography.
- It's designed to provide strong authentication for users accessing network services.

⇒ Key components of Kerberos :-

① Key Distribution Center (KDC):

- A trusted third party that issues tickets to clients.
- It consists of two main services:
 - Authentication Service (AS): Authenticates users and issues ticket-granting tickets (TGTs).
 - Ticket Granting Service (TGS): Issues service tickets to clients.

② Client : A user or a service that requests access to network resources.

③ Server: A network service that provides resources to authenticated clients.

⇒ Kerberos Authentication Process :-

① Initial Authentication :-

- The client sends a request to the KDC's Authentication Server (AS) to authenticate itself.
- The AS issues a Ticket-Granting Ticket (TGT) to the client, encrypted with the client's secret key.

② Service Request :-

- The client sends the TGT to the Ticket-Granting Server (TGS) to request a service ticket for a specific service.
- The TGS issues a service ticket, encrypted with the service's secret key.

③ Service Access :-

- The client presents the service ticket to the server.
- The server decrypts the ticket using its secret key and grants access to the requested service.

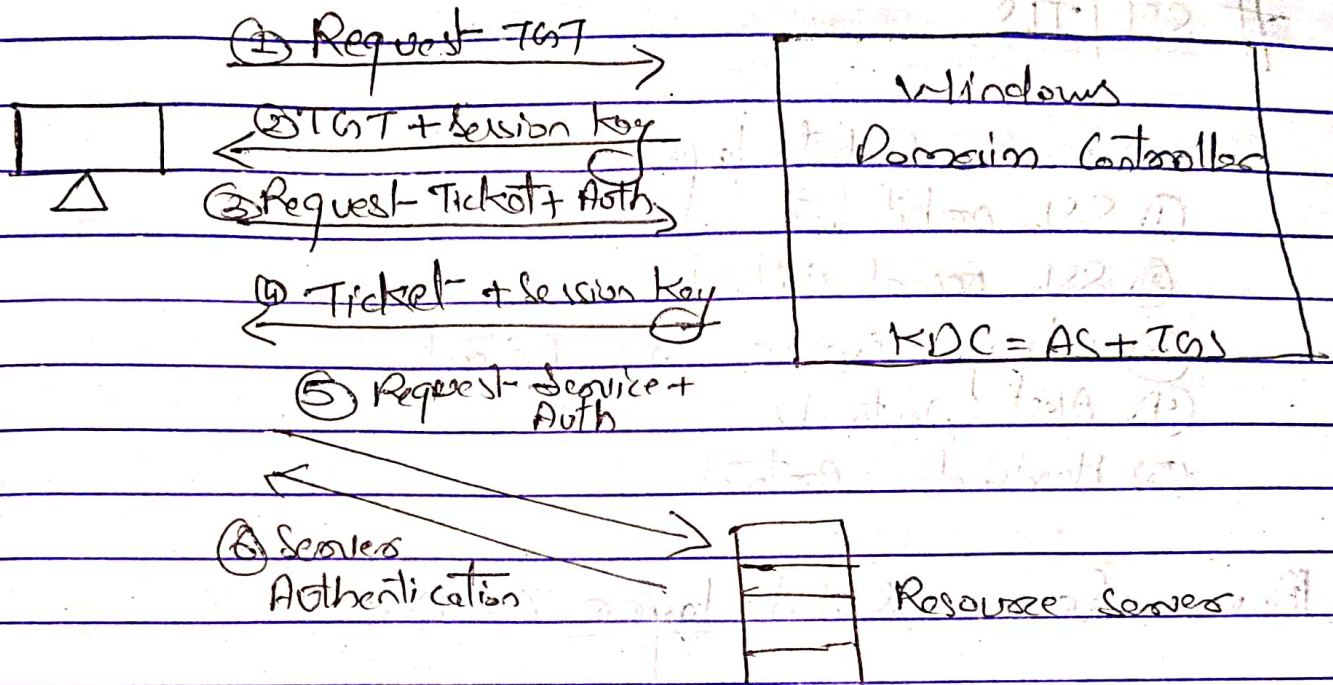


Fig: Kerberos authentication protocol

⇒ Key Benefits :-

- ① **Strong Security** - use strong cryptography to protect users credentials
- ② **Single Sign-on (SSO)** - Allows users to authenticate once and access multiple services
- ③ **Scalability** - Can handle large no.s of users & services.
- ④ **Interoperability** - works across different platforms and OS.

8th most imp

SSL/TLS

SSL → Secure Sockets Layer

- ① SSL architecture
- ② SSL Record Protocol
- ③ Change Cipher Spec Protocol
- ④ Alert protocol
- ⑤ Handshake Protocol

Ans. Secure Socket Layer (SSL):-

- SSL is an Internet security protocol that encrypts data to keep it safe.
- It provides security to the data that is transferred b/w web browsers and servers.
- SSL is old version of what we call now TLS (Transport Layer Security).
- Websites using SSL/TLS have "HTTPS" in their URL instead of "HTTP".

⇒ Core Functions:-

- Encryption - protects data confidentiality
- Authentication - verifies the identity of the communicating parties
- Integrity - ensures data integrity and prevents tampering.

HTTP	FTP	SMTP
SSL or TLS		
TCP		
IP		
① Transport level		

→ SSL / TLS Architecture

SSL Handshake Protocol	SSL Change Cipher Spec Protocol	SSL Alert Protocol	HTTP
SSL Record Protocol			
TCP			
IP			

fig: SSL Protocol Stack

⇒ Secure Socket Layer Protocols

- ① SSL Record Protocol
- ② Handshake Protocol
- ③ Change - Cipher Spec Protocol
- ④ Alert Protocol

→ Two important SSL concepts are the SSL session and the SSL connection

- Connection - A connection is a transport that provides a suitable type of service.
 - For SSL, such connections are peer-to-peer relationships.

The connections are transient.

- Session - An SSL session is an association between a client and a server.
Sessions are created by the Handshake Protocol.

⇒

→ SSL Record Protocol

- The SSL Record Protocol provides two services for SSL connects :-

① Confidentiality - the handshake protocol defines a shared secret key that is used for conventional encryption of SSL payloads

② Message Integrity - The Handshake protocol also defines a shared secret key that is used to form a message authentication code (MAC).

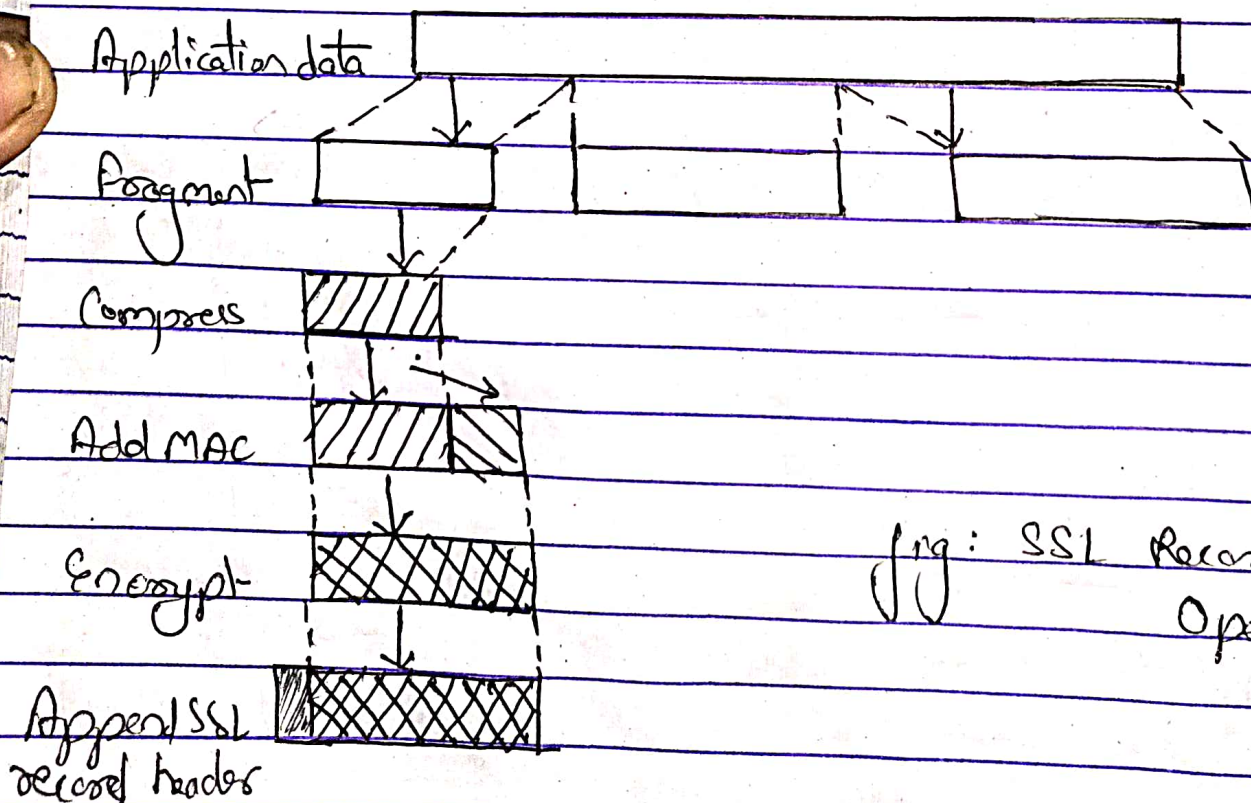


Fig: SSL Record Protocol Operation

- In SSL Record application data is divided into fragments.
- The fragment is compressed and then encrypted. MAC (Msg Authentication Code) generated by algorithms like SHA (Secure Hash Protocol) and MD5 (Msg Digest) is appended.
- After that encryption of the data is done and in last SSL Header is appended to the data.

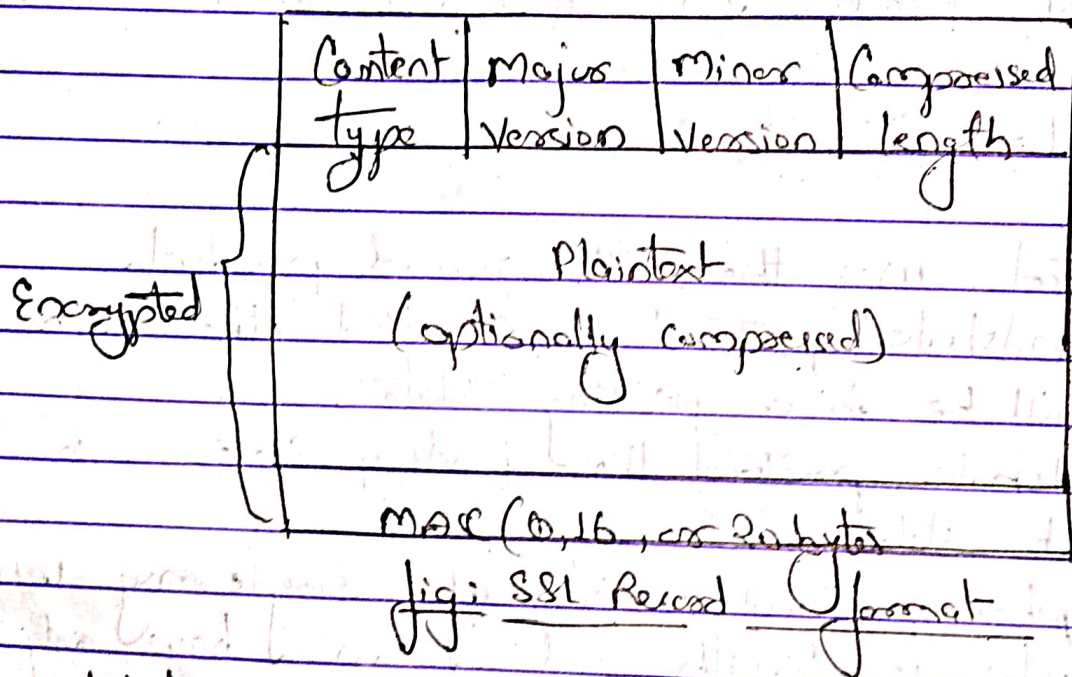
→ Change - Cipher Protocol

- This protocol uses the SSL record protocol.
 - Unless Handshake protocol is completed, the SSL record op will be in a pending state.
 - After handshake protocol, the pending state is converted into current state.
- Change - cipher protocol consists of a single msg which is 1 byte in length and can have only one value.
- This protocol purpose is to cause the pending state to be copied into current state.

1 byte

→ Alert Protocol :-

- The Alert protocol is used to convey SSL-related alerts to the peer entity. As with other applications that uses SSL, alert msgs are compressed and encrypted, as specified by the current state.



1-byte
1

Ⓐ Change-Cipher Spec Protocol

1 byte	2 bytes	≥ 2 bytes
Type	length	Content

Ⓑ Handshake Protocol

1 byte	1 byte
level	Alert

Ⓒ Alert Protocol

≥ 1 byte
Opaque content

Ⓓ other upper-layer Protocol (eg HTTP)

fig: SSL Record Protocol Payload

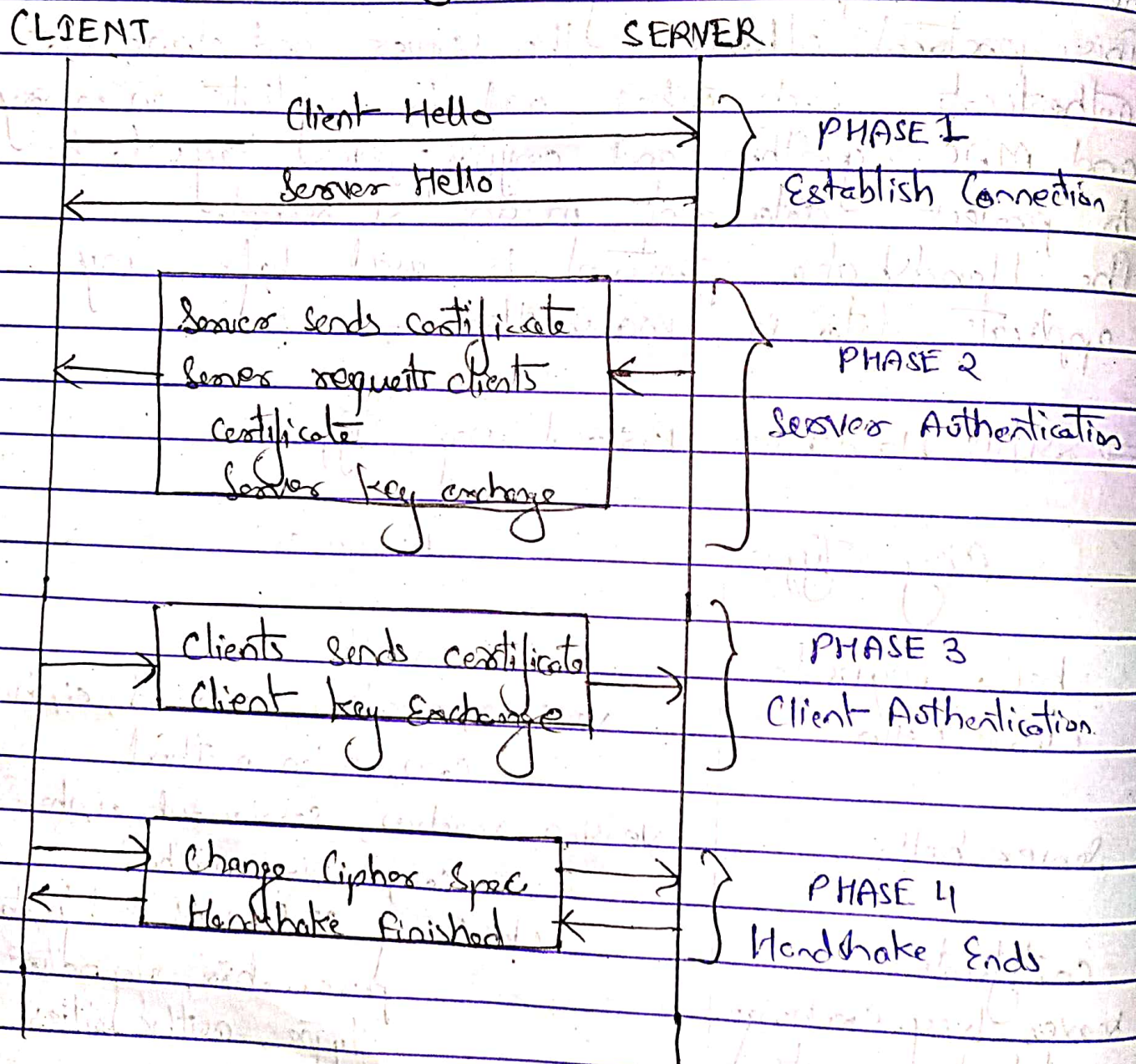
Most important → Handshake Protocol (SSL/TLS)

- The most complex part of SSL is the Handshake Protocol
- This protocol allows the server and client to authenticate each other and to negotiate an encryption and MAC algorithm and cryptographic keys to be used to protect data sent in an SSL record.
- The Handshake protocol is used before any application data is transmitted.

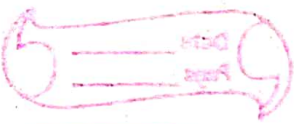
⇒ SSL/TLS Handshake Protocol msg Types:-

Msg Type	Parameters
hello-request client-hello	null version, random, session id, cipher suite, compression method
server-hello	version, random, session-id, cipher suite, compression method
certificate server-key-exchange certificate-request	chain of X.509v3 certificates parameters, signature type, authorities
server-done	null
certificate-verify client-key-exchange finished	signature parameters, signature hash value

⇒ Handshake protocol uses four phases to complete its cycle :-



SSL Handshake
protocol

- 
- 
- Phase 1 : Both client & server send hello-packets to each other. In this SP session, cipher suite & protocol version are exchanged for security purposes.
 - Phase 2 : Server sends his certificates and server-key-exchange.
 - Phase 3 : Client replies to the server by sending his certificates and client-exchange-key.
 - Phase 4 : Change-cipher suite occurs and after this the Handshake protocol ends.